RECKLABS

SERVICES PRIVATE LIMITED
Your ROI Partner | recklabs.com
CP-202, Saraswati Vihar, Pitampura, New Delhi — 110034

AI MCP Platform

Open Source AI Connector Platform

Product Roadmap, Architecture & Business Strategy

Prepared by: Recklabs Services Private Limited — Internal Team

Date: 17 April 2026

Version: 1.0 — Draft for Review

Executive Summary

This document outlines the full product strategy, technical architecture, and business model for an open-source AI connector platform. The platform bridges the gap between complex, fragmented open-source AI tools and business clients who need plug-and-play AI capabilities for their day-to-day operations.

The platform is built around Anthropic's Model Context Protocol (MCP) — an open standard that allows AI models to connect with external applications and data sources. By curating, packaging, and maintaining a library of MCP connectors, the platform enables any business to deploy AI workflows without technical expertise.

The roadmap is structured in four phases:

- Phase 1: Foundation — Website, connector library, Claude Desktop integration, skill files, one-click installer
- Phase 2: Multimodal — Voice, image, document, and email inputs across all connectors
- Phase 3: Local LLM — Full on-premise deployment using open-source models (Llama, Gemma, Mistral)
- Phase 4: Platform & Ecosystem — Developer marketplace, white labeling, managed services

---

Core Business Concept

The Problem We Solve

Open-source AI tools are powerful but fragmented, unstable, and difficult to configure. Business clients — CA firms, sales teams, HR departments — have no way to leverage these tools without significant technical resources.

At the same time, Claude Desktop (free, Windows) provides a powerful AI interface that any business can use today. The missing piece is a reliable, curated library of connectors that bridge Claude to the tools businesses already use.

Our Value Proposition

What We Do	Value to Client
Curate open-source MCP connectors from GitHub	No need to find, evaluate, or test connectors
Maintain stable, tested versions	Connectors don't break when upstream changes
Package as one-click installer	Zero technical setup required
Provide industry-specific workflow templates	Ready-to-use AI workflows out of the box

What We Do	Value to Client
Curated, encrypted base skill files per connector	Our market expertise pre-loaded — clients get best practices instantly
Periodic skill file updates with subscription	Skill files keep improving automatically — continuous value delivered
Support local LLM option (Phase 3)	Full data privacy, no cloud dependency

The 'Red Hat' Analogy

Red Hat took free Linux (open source) and built a billion-dollar business by making it enterprise-ready — with support, stability, and packaging. We are doing the same for open-source AI/MCP tools. The tools are free; the value we add is curation, stability, packaging, and support.

Platform Architecture

Overall System Design

The architecture is designed so that client credentials and data never leave the client's machine. Your servers only handle the website, connector library files, and license validation.

Layer	What It Is	Where It Lives
Website & Library	Connector packages, docs, installer download	Your cloud server
License Server	Validates subscription keys, controls access	Your cloud server
One-Click Installer	Downloads & configures selected connectors	Downloaded by client
Local MCP Server	Runs the selected connectors on client machine	Client's Windows PC
Claude Desktop	The AI interface / brain	Client's Windows PC
Connectors	Zoho, Tally, Apollo, Lusha, QuickBooks, etc.	Client's Windows PC
Skill Files	Client's credentials, workflows, app configs	Client's Windows PC

Why MCP Server Runs Locally on Client Machine

- Client credentials (Zoho API keys, QuickBooks login, etc.) never pass through your servers
- No cloud hosting costs for compute — you only host files and license validation

- Works offline once installed — no internet dependency for daily use
- Fully compliant with enterprise security policies
- Claude Desktop on Windows is natively designed for local MCP server connections

What Your Website Hosts

- Connector packages (downloadable files for each connector)
- Documentation for each connector
- The one-click installer/setup script
- Skill file templates per connector and industry
- License management portal

Phase 1: Foundation

Objectives

- Launch website with connector library
- Build and curate library of MCP connectors sourced from open-source GitHub repositories
- Create library of Claude skills, agents, and plugins
- Develop one-click installer for Windows
- Implement skill file system for client resource configuration
- Launch subscription/license model

Key Deliverables

1. Website

- Landing page explaining the platform and value proposition
- Connector library browser — searchable, filterable by category
- Documentation pages for each connector
- Pricing and subscription management
- Download portal for the installer

2. Connector Library

Sourced from open-source GitHub repositories, curated, tested, and maintained:

Category	Connectors
Accounting & Finance	Zoho Books, Tally, QuickBooks, FreshBooks
Lead Generation	Apollo.io, Lusha, LinkedIn scraper, Hunter.io

Category	Connectors
CRM	Zoho CRM, HubSpot, Salesforce (open connectors)
Communication	Gmail, Outlook, Slack, WhatsApp Business
Productivity	Google Drive, Notion, Trello, Asana
Custom	Client-specific connectors built on request

3. Skill File System

The skill file system operates in four layers working together:

Layer 1 — Our Curated Base Skill Files (Platform-Maintained)

We create and maintain a base skill file for each connector, built from our own market research and hands-on experience with the tool. This comes pre-loaded with:

- Best-practice workflows for that connector based on real business use cases
- Recommended settings, optimal API call sequences, and known edge cases
- Industry-specific defaults (e.g., Tally skill file tuned for Indian accounting standards)
- Error handling patterns discovered through testing and client feedback

This is our IP — the accumulated knowledge of how to get the best out of each tool, packaged into the skill file. Clients cannot easily replicate this on their own.

Layer 2 — Client Customisation Layer

On top of our base skill file, each client adds their own layer:

- Their specific API credentials and authentication tokens (stored locally, never transmitted to our servers)
- Their own workflows, business rules, and automation sequences
- Custom preferences — naming conventions, approval workflows, reporting formats
- Business-specific parameters — GST numbers, chart of accounts, CRM field mappings
    - A UI-based skill file editor lets clients update their layer without editing raw files
    - The client layer sits on top of our base layer — our defaults apply unless the client overrides them

Layer 3 — Encryption of Our Base Skill Files

Our curated base skill file layer will be encrypted so that:

- Clients cannot view or copy our proprietary workflow logic and best-practice configurations
- Our IP is protected even though the file lives on the client machine
- Only our platform runtime (the local MCP server) can decrypt and execute the base layer
- The client customisation layer remains fully readable and editable by them

Skill File Layer	Who Creates It	Encrypted?	Client Can Edit?
Base skill file	Our team (market expertise)	Yes — AES-256 encrypted	No — read-only
Client customisation layer	Client (via UI editor)	No — plain config	Yes — fully editable
Combined runtime file	Auto-merged by MCP server	Base layer stays encrypted	N/A — runtime only

Layer 4 — Periodic Skill File Updates (Ongoing Subscription Value)

Our base skill files are living documents — continuously improved based on:

- New features released by the connector tool (e.g., Zoho adds a new API endpoint)
- Feedback and usage patterns aggregated across our client base
- Changes in best practices, compliance requirements, or market standards
- Bugs, edge cases, and performance improvements discovered over time

Clients receive updated base skill files automatically as part of their subscription:

- Updates pushed periodically — monthly or whenever a connector has a major change
- The client customisation layer is never touched during updates — only our base layer is replaced
- Clients are notified of what changed in each update via a changelog per connector
- This is a strong ongoing reason to maintain the subscription — the skill file gets smarter over time

This periodic update model creates continuous delivered value, not just a one-time setup. It is one of the strongest justifications for the recurring subscription fee.

4. One-Click Installer

- Client selects desired connectors on the website
- A customized installer package is generated
- Client downloads and runs — single click sets up everything
- Installs local MCP server, selected connectors, and configures Claude Desktop
- License key entered during installation activates selected connectors

Additional Phase 1 Features

Connector Health Dashboard

A local dashboard showing clients which connectors are active, last sync time, and any errors. Reduces support calls and builds client confidence.

Connector Versioning

Open-source connectors break when upstream repos change. We maintain a stable, tested version of each connector — this alone is a core part of our value proposition.

Community Contribution Portal

Developers can submit new connectors to the library. We review, test, and certify them. This creates a marketplace flywheel without us having to build every connector.

Phase 2: Multimodal Capabilities

Objectives

Extend the platform to accept non-text inputs — images, voice, documents, emails — and produce rich outputs. The underlying MCP connectors do not change; only the input/output layer is enhanced.

Input Modalities Added

Input Type	Example Use Case	Connector Triggered
Document / PDF	Upload invoice → auto-book in Tally	Tally connector
Image	Photo of business card → enriched lead	Apollo / Lusha connector
Voice	Speak a command → log expense	QuickBooks connector
Screenshot	Paste screenshot → extract & process data	Any connector
Email	Incoming email → create deal in CRM	Zoho CRM connector

Output Modalities Added

- Generated reports with charts and visual summaries
- Auto-generated documents — proposals, invoices, summaries
- Drafted emails ready for one-click sending
- Voice responses — Claude speaks back results

Industry-Specific Packs

Pre-built bundles of connectors + skill files + workflows for specific verticals:

Pack Name	Included Connectors	Key Workflows
CA / Accounting Firm Pack	Tally, QuickBooks, Google Drive	Invoice booking, GST filing prep, expense tracking
B2B Sales Pack	Apollo, Lusha, LinkedIn, Gmail	Lead enrichment, qualification, email outreach
HR / Recruitment Pack	LinkedIn, Gmail, Google Drive	Resume parsing, candidate tracking, interview scheduling
E-commerce Pack	Shopify connector, Gmail, QuickBooks	Order management, customer follow-up, accounting sync

Workflow Builder UI

A visual drag-and-drop interface on the website where clients build their own workflows. The builder auto-generates the skill file. This is a major differentiator — no competitor currently offers this for MCP workflows.

Planning Note for Phase 1

Design the skill file schema in Phase 1 to include a modality flags field per connector (e.g., supports: [text, image, voice, document]). This avoids rework when Phase 2 is built.

Phase 3: Local LLM (On-Premise)

Objectives

Replace Claude Desktop with a locally running open-source LLM (Llama, Gemma, Mistral, etc.) so that the entire stack runs on the client's machine with zero cloud dependency. All connectors and skill files from Phases 1 and 2 remain unchanged — only the AI brain is swapped.

Why This Is Possible

MCP (Model Context Protocol) is model-agnostic by design. It works with any LLM, not just Claude. This means the connector library built in Phase 1 requires zero rework to support local LLMs in Phase 3.

Phase 3 Architecture

Component	Phase 1 & 2	Phase 3
AI Brain	Claude Desktop (Anthropic cloud)	Ollama running Llama / Gemma / Mistral (local)

Component	Phase 1 & 2	Phase 3
MCP Server	Local on client machine	Same — unchanged
Connectors	All connectors from library	Same — unchanged
Skill Files	Client config files	Same — unchanged
Data Privacy	API calls to Anthropic	100% on-premise, no data leaves machine

Recommended Local LLM Options

Model	Best For	Min. RAM Required
Llama 3.2	General purpose, strong reasoning	16 GB
Gemma 3	Lightweight, fast, Google-backed	8 GB
Mistral 7B	Business/enterprise tasks	16 GB
Phi-4	Very small, surprisingly capable	8 GB
Qwen 2.5	Multilingual (strong for India)	16 GB

Runtime: Ollama

Ollama is the recommended local LLM runtime for Windows. It is free, open-source, and supports MCP connections. The one-click installer in Phase 3 will include Ollama setup alongside the existing MCP server configuration.

New Business Opportunities in Phase 3

Air-Gapped Enterprise Package

Full on-premise deployment with no internet required after setup. Target: banks, legal firms, government agencies, healthcare providers. These clients pay premium prices for compliance and data privacy guarantees.

Fine-Tuning Service (Premium)

Take an open-source LLM and fine-tune it on the client's own historical data. Example: a CA firm's historical Tally data trains a model that deeply understands their books and accounting style. Charge a one-time fine-tuning fee plus annual maintenance.

Model Recommendation Engine

Based on the client's hardware specifications and use case, automatically recommend the best local LLM. Reduces friction and builds client confidence during onboarding.

Planning Notes for Phase 1 & 2

- Keep MCP server strictly model-agnostic — do not use Claude-specific features that can't be replicated
- Add an 'llm_provider' field to skill files from Phase 1 (e.g., claude, ollama, gemma) for easy switching
- Document minimum hardware requirements on the website from Phase 1 onwards

---

Phase 4: Platform & Ecosystem

Objectives

Transform the product from a SaaS tool into a full platform with a developer ecosystem, white-label reseller program, and managed enterprise services.

Initiative	Description	Revenue Model
Developer Marketplace	Third-party developers build and sell connectors on our platform	Revenue share (30/70 split)
White Label Program	Resellers brand the platform as their own for their clients	Monthly reseller license fee
Managed Service	We handle full deployment and management for enterprise clients	Monthly retainer
Training & Certification	Certify 'MCP AI Developers' — builds community + pipeline	Course fees + exam fees
Connector Analytics	Show clients how their AI workflows are performing	Premium tier add-on

---

Business Model & Monetization

Recommended Model: Subscription + License Key

Clients pay a monthly or annual subscription. Connectors are locked until a valid license key is entered. The license key is validated against your server at activation. Access is revoked automatically if the subscription lapses.

This model is recommended because:

- Generates predictable recurring revenue
- Credentials always stay on the client machine — only the license check hits your server
- Easy to tier by number of connectors or feature set
- Simple to implement and explain to clients

Suggested Pricing Tiers

Plan	Connectors Included	Features	Target Client
Starter	Up to 3 connectors	Basic skill files, community support	Freelancers, micro businesses
Professional	Up to 10 connectors	Workflow builder, priority support, updates	SMBs, CA firms, sales teams
Enterprise	Unlimited connectors	Custom connectors, fine-tuning, SLA, white label	Large businesses, corporates
Air-Gapped (Phase 3)	All connectors, local LLM	Full on-premise, compliance package	Banks, legal, government

Additional Revenue Streams

- One-time setup and onboarding fee per enterprise client
- Custom connector development — build bespoke connectors for specific client needs
- Fine-tuning service — train local LLMs on client data (Phase 3)
- Developer marketplace revenue share (Phase 4)
- Training and certification programs (Phase 4)

Target Verticals (Phase 1 Focus)

Rather than launching as a generic platform, Phase 1 should target 2–3 specific industries deeply. This gets paying clients faster and creates strong case studies for broader expansion.

Vertical	Key Connectors	Primary Pain Point Solved
CA / Accounting Firms	Tally, QuickBooks, Google Drive, Gmail	Manual data entry, invoice processing, GST preparation
B2B Sales Teams	Apollo, Lusha, LinkedIn, Gmail, Zoho CRM	Lead enrichment, outreach automation, CRM data entry
HR / Recruitment	LinkedIn, Gmail, Google Drive, Zoho People	Resume screening, candidate tracking, interview scheduling

---

Full 4-Phase Roadmap Summary

Phase	Focus	Key Milestones	New Revenue
Phase 1 Foundation	Website, connector library, Claude Desktop, skill files, installer, license model	Website live, 10+ connectors, first paying clients	Subscription fees

Phase	Focus	Key Milestones	New Revenue
Phase 2 Multimodal	Voice, image, document, email inputs; workflow builder; industry packs	3 industry packs live, workflow builder launched	Higher-tier subscriptions, pack pricing
Phase 3 Local LLM	Ollama/Llama/Gemma support, air-gapped enterprise, fine-tuning service	First enterprise air-gapped deployment, fine-tuning offering	Enterprise contracts, fine-tuning fees
Phase 4 Ecosystem	Developer marketplace, white label, managed services, certification	10+ third-party connectors, first white-label reseller	Marketplace cut, reseller fees, training revenue

---

Parallel Workstreams for Team

The following workstreams can be executed in parallel by different team members:

Workstream	Responsible	Phase 1 Deliverable
Website Design & Development	Frontend / Web team	Landing page, connector library browser, download portal
Connector Research & Curation	Technical team	List of 15–20 vetted open-source connectors from GitHub
Installer Development	Backend / DevOps team	One-click Windows installer with MCP server setup
Skill File Schema Design	Product / Architecture team	Skill file spec document and sample templates
License & Subscription System	Backend team	License key generation, validation API, payment integration
Industry Pack Research	Business / Product team	Workflow definitions for CA firm and Sales team packs
Documentation	Technical writing team	Per-connector docs, getting started guides, FAQ

Important Technical Notes

MCP Protocol

MCP (Model Context Protocol) is an open standard developed by Anthropic. It is model-agnostic — it works with Claude, Llama, Gemma, Mistral, and any other LLM that supports tool use. Building on MCP ensures our connector library is future-proof and not locked to any single AI provider.

Claude Desktop

Claude Desktop is Anthropic's free Windows application. It natively supports local MCP server connections, making it the ideal starting point for Phase 1 — no API costs for the client, easy setup, and a polished AI interface.

Security Design Principle

A core design principle of this platform is that sensitive client data — API keys, credentials, financial data — never passes through our servers. The MCP server runs locally. Our servers only handle connector package files and license key validation. This is a feature, not a limitation, and should be prominently marketed to enterprise clients.

Skill File Architecture & IP Protection

The skill file system is a two-layer architecture. The base layer is created by our team and encrypted using AES-256 before being distributed to clients. The encryption key is embedded in the licensed MCP server runtime — so only a valid, licensed installation can decrypt and use our base skill files. This protects our IP regardless of where the file physically resides.

The client customisation layer sits on top and is never encrypted — clients must be able to read and edit their own credentials and workflows freely. The MCP server merges both layers at runtime before executing any workflow.

Periodic updates replace only the base layer. The update mechanism fetches the new encrypted base skill file from our server (authenticated by the client's license key) and overwrites the old one. The client layer is always preserved.

Open-source projects can change or break at any time. Our connector library will pin to specific stable versions of upstream connectors and maintain our own tested forks where necessary. Clients will receive updates through the installer update mechanism, not by pulling directly from upstream GitHub.

Security Architecture & Compliance — India (Domestic Operations)

This section is critical. Every phase of the platform must be designed with Indian law compliance built-in from Day 1 — not retrofitted later. This covers the three primary legal frameworks applicable to Recklabs, the security architecture mandated by each, and specific design decisions required in each phase.

NOTE: This document is for internal planning purposes only and does not constitute legal advice. Recklabs must engage qualified legal counsel before launch to confirm compliance with all applicable laws.

Applicable Indian Legal Framework

Three major legal instruments govern Recklabs' operations. All are currently in force or entering enforcement phase:

Law / Regulation	Governing Body	Key Penalty	Enforcement Status
DPDP Act 2023 + DPDP Rules 2025	Data Protection Board of India (DPBI)	Up to ₹250 crore per incident; ₹10,000 crore for repeated severe violations	DPBI operational Nov 2025. Full enforcement from May 13, 2027. Complaint-driven enforcement already active.
IT Act 2000 — Section 43A + SPDI Rules 2011	Adjudicating Officers under MeitY	Compensation to affected individuals; up to ₹1 crore fine	Currently in force. Will be superseded by DPDP Act on full enforcement.
CERT-In Directions 2022 (under IT Act Section 70B)	CERT-In / MeitY	Imprisonment up to 1 year and/or fine up to ₹1 lakh. Ongoing non-compliance can attract further action.	In full force since June 2022. Applies to ALL entities operating in India.

1. DPDP Act 2023 — What It Means for Recklabs

Does It Apply to Recklabs?

Yes — without question. The DPDP Act applies to any entity incorporated in India that processes digital personal data as part of its business operations, regardless of size or revenue. There is no employee count threshold or revenue floor. Recklabs processes personal data in two ways: (a) data about its own clients (names, emails, payment info) collected during subscription, and (b) as a tool provider whose software processes client employee and customer data through connectors.

Recklabs' Role Under DPDP

Data Type	Recklabs' Role	Obligation
Client subscription data (names, emails, billing)	Data Fiduciary — Recklabs determines the purpose and means of processing	Full DPDP obligations: consent, privacy notice, erasure, breach notification, DPO if scaled
Data flowing through connectors on client machines (Tally records, CRM contacts, financial data)	Data Processor — acting on behalf of the client business	Contractual protections with clients required: processing scope, security obligations, breach notification clauses, deletion on termination
Employee data of client businesses	Data Processor	Same as above — must not use data beyond the contracted scope

Data Type	Recklabs' Role	Obligation
processed through HR connectors		

Key DPDP Obligations — Phased Compliance Deadlines

Obligation	Deadline	What Recklabs Must Do
Privacy notice — standalone, plain language, before data collection	Immediate (Rules active Nov 2025)	Publish a DPDP-compliant privacy notice on the website before launch. Must specify exactly what data is collected and for what purpose.
Explicit, free, unconditional consent before collecting personal data	Immediate	Consent cannot be bundled with T&Cs. A separate consent mechanism is required at account creation and subscription.
Right to erasure — respond within 7 days of request	Immediate	Build a data deletion workflow into the subscription management system. Client data must be fully deletable on request.
Breach notification to DPBI within 72 hours	Immediate	Establish an incident response procedure and designate a breach notification officer before launch.
Consent Manager registration (if operating as intermediary)	November 2026	Evaluate whether Recklabs qualifies as a Consent Manager. If yes, must register with DPBI — requires Indian incorporation and ₹2 crore net worth.
Significant Data Fiduciary (SDF) obligations — DPO, DPIA, audits	May 13, 2027	Monitor user scale. Companies with 50 lakh+ users or ₹250 crore+ revenue likely qualify. Plan for DPO appointment and annual audits if growth trajectory warrants.
Full substantive compliance — all privacy rights, security safeguards, retention policies	May 13, 2027 (absolute deadline)	All systems must be fully compliant by this date. No grace period after this.

Architecture Design Decisions Required by DPDP

- Data minimisation by design — connectors must collect only the data fields strictly necessary for the stated workflow purpose. No speculative collection.
- Purpose limitation — data collected for Tally invoice booking must not flow into Apollo lead enrichment. Each connector's data scope must be isolated.
- No data aggregation on Recklabs servers — all processing happens locally on client machine. Recklabs servers must never receive, store, or process client business data.
- Retention and deletion controls — the skill file system must include a data retention policy field. The local MCP server must be capable of purging data on instruction.
- Multilingual privacy notice — DPDP Rules require notices in English or any of India's 22 constitutional languages based on the user's preference. The website must support this.

- Children's data protection — if any connector could touch data of individuals under 18 (HR systems, education platforms), verifiable parental consent via DigiLocker integration is mandatory.

2. IT Act 2000 — Section 43A + SPDI Rules 2011

Section 43A currently applies until the DPDP Act fully supersedes it (expected May 2027). It holds any body corporate liable for negligence in protecting Sensitive Personal Data or Information (SPDI), which includes: financial information, passwords, biometric data, health records, and sexual orientation.

What Counts as SPDI in Recklabs' Context

- Financial information flowing through Tally and QuickBooks connectors — bank account details, transaction records, tax data — is explicitly SPDI
- Passwords or API keys stored in skill files — these must be encrypted at rest and never logged
- Employee health or biometric data if HR connectors are used

Section 43A Compliance Requirements

- Implement and maintain 'reasonable security practices' — in practice this means ISO 27001 or equivalent controls
- Written information security policy covering access control, encryption, incident response, and vendor management
- Third-party audits recommended — Section 43A compliance is demonstrated through documented security practices, not self-declaration
- Skill files containing financial credentials must be encrypted at rest (AES-256 already planned — this satisfies the requirement)

3. CERT-In Directions 2022 — Mandatory Cybersecurity

The CERT-In Directions under IT Act Section 70B(6) are in full force and apply to ALL service providers, intermediaries, data centres, and body corporates operating in India. Recklabs qualifies as a body corporate and intermediary. Non-compliance can result in imprisonment of up to 1 year.

Mandatory CERT-In Requirements for Recklabs

Requirement	What It Means for Recklabs	Phase to Implement
Report cybersecurity incidents to CERT-In within 6 hours of detection	Any breach, data leak, ransomware, or unauthorised access affecting Recklabs systems must be reported within 6 hours — not 6 business hours, 6 clock hours.	Phase 1 — before launch

Requirement	What It Means for Recklabs	Phase to Implement
Appoint a Point of Contact (PoC) for CERT-In	Designate a named employee as the CERT-In PoC. Register their details with CERT-In. Keep details updated.	Phase 1 — before launch
Maintain ICT system logs for 180 days within India	All server logs, application logs, and access logs from Recklabs' own servers must be retained for 180 days and stored within Indian jurisdiction (or a copy maintained in India).	Phase 1 — from first day of operation
Synchronise all ICT system clocks with NIC or NPL NTP servers	All Recklabs servers must sync time with government-designated NTP servers (ntp.nic.in). This is a mandatory technical control.	Phase 1 — infrastructure setup
Provide logs and assistance to CERT-In on demand	If CERT-In issues a direction for information, Recklabs must comply within the specified timeframe — which can be near real-time.	Ongoing — operational policy
KYC of clients (for service providers)	Maintain accurate name, address, and contact details of all subscribers. These records must be maintained for 5 years from termination of the subscription.	Phase 1 — subscription system design

CERT-In and the Local-First Architecture Advantage

A key benefit of the Recklabs local-first architecture is that client business data never passes through Recklabs servers — meaning CERT-In's log retention obligations apply only to Recklabs' own operational systems (website, license server, update server), not to the vast volumes of financial and CRM data flowing through client-side connectors. This is a significant compliance advantage over cloud-based competitors.

Security Architecture — Phase by Phase

Phase 1 Security Architecture

Security Control	Implementation	Legal Requirement Satisfied
AES-256 encryption of base skill files	Encrypted before distribution; decrypted only by licensed MCP server runtime	IT Act Section 43A — reasonable security for SPDI
Client credentials stored locally only	API keys, passwords never transmitted to Recklabs servers	DPDP Act — data minimisation; CERT-In — no central credential store to breach
HTTPS/TLS for all Recklabs server communications	License validation, update downloads, website — all over TLS 1.3	IT Act Section 43A — reasonable security practices

Security Control	Implementation	Legal Requirement Satisfied
CERT-In PoC appointed and registered	Named employee designated before launch	CERT-In Directions 2022 — mandatory
180-day log retention on Recklabs servers in India	Structured logging with 180-day retention, Indian hosting	CERT-In Directions 2022 — mandatory
NTP synchronisation to NIC/NPL servers	All Recklabs infrastructure synced to ntp.nic.in	CERT-In Directions 2022 — mandatory
DPDP-compliant privacy notice on website	Standalone notice, plain language, specifying data categories and purposes	DPDP Act 2023 — immediate obligation
Explicit consent mechanism at signup	Separate consent checkbox, not bundled with T&Cs	DPDP Act 2023 — immediate obligation
72-hour breach notification procedure	Written incident response plan, designated breach officer	DPDP Act 2023 — immediate obligation
Client KYC records maintained for 5 years	Name, address, contact of all subscribers — retained post-termination	CERT-In Directions 2022 — subscriber records
DPDP-compliant client contracts	Data processing agreements with clients defining scope, security obligations, deletion on termination	DPDP Act 2023 — processor obligations

Phase 2 Security Architecture — Additional Controls

Security Control	Implementation	Why Needed in Phase 2
Multimodal data isolation	Images, voice, documents processed locally — never uploaded to Recklabs servers	DPDP Act — data minimisation; biometric/health data in images may be SPDI under IT Act
Document data retention controls	Processed documents purged from local memory after workflow completion — no persistent storage without explicit client instruction	DPDP Act — storage limitation principle
Voice data protection	Voice inputs processed locally via local STT — no cloud speech APIs unless client explicitly consents	DPDP Act — consent required for biometric-adjacent data
Industry pack data flow documentation	Each industry pack must have a documented data flow map showing exactly what data moves where	DPDP Act — purpose limitation; supports DPIA if Recklabs scales to SDF level
MCPX Tool Groups for multi-user clients	Restrict each user's connector access to their role — accounts team cannot access HR data	IT Act Section 43A — access control; DPDP Act — data minimisation

Phase 3 Security Architecture — Enterprise & Local LLM

Security Control	Implementation	Why Critical in Phase 3
Air-gapped deployment option	Full on-premise: no internet required post-setup. Zero data leaves client premises.	Banks, legal firms, government — regulatory requirement for data sovereignty
Local LLM data isolation	LLM inference happens locally — no prompts or responses sent to any cloud API	DPDP Act — sensitive financial/HR data in prompts must not leave jurisdiction
MCPX Enterprise immutable audit trails	Full chain logging: User → Agent → MCP Server → Tool — retained per CERT-In 180-day requirement	CERT-In Directions 2022; enterprise client compliance requirements
Fine-tuning data security	Training data for custom LLMs must be anonymised before use; fine-tuned model stays on client premises	DPDP Act — purpose limitation; IT Act Section 43A for SPDI in training data
Significant Data Fiduciary readiness	If Recklabs reaches 50 lakh users or ₹250 crore revenue, DPO appointment, annual DPIA, and independent audit become mandatory	DPDP Act — SDF obligations effective May 2027
ISO 27001 certification recommended	Third-party audit of security controls — demonstrates reasonable security practices under IT Act Section 43A	Needed for enterprise client procurement requirements; supports DPDP compliance

Legal Compliance Roadmap — Action Items by Date

Deadline	Action Required	Owner
Before website launch	Publish DPDP-compliant privacy notice	Legal + Product
Before website launch	Implement explicit consent mechanism at signup	Engineering + Legal
Before website launch	Appoint CERT-In Point of Contact and register with CERT-In	Management
Before website launch	Set up 180-day log retention on Indian servers	DevOps
Before website launch	Synchronise all servers to NIC/NPL NTP	DevOps
Before website launch	Draft DPDP-compliant data processing agreement template for client contracts	Legal
Before website launch	Write incident response plan with 6-hour CERT-In and 72-hour DPBI notification procedure	Legal + Engineering

Deadline	Action Required	Owner
Before first client onboarding	Implement 7-day data erasure workflow for client subscription data	Engineering
Before first client onboarding	Implement 5-year KYC record retention for subscribers	Engineering
November 2026	Evaluate Consent Manager registration requirement with DPBI	Legal + Management
May 2027	Full DPDP compliance audit — all privacy rights, security safeguards, retention policies	Legal + External Auditor
Phase 3 launch	Engage legal counsel for air-gapped enterprise contracts — sector-specific compliance (banking, healthcare)	Legal
At 50 lakh users or ₹250 crore revenue	Appoint India-based Data Protection Officer; commence annual DPIA; engage independent auditor	Management + Legal

Open Source Licence Compliance

All connectors sourced from GitHub must be licence-audited before inclusion in the Recklabs library. This is both a legal obligation and a business risk:

Licence Type	Can Recklabs Use It Commercially?	Conditions
MIT	Yes — preferred	Must include copyright notice. No other restrictions.
Apache 2.0	Yes — preferred	Must include NOTICE file. Patent grant included.
BSD 2/3-Clause	Yes	Must include copyright notice.
GPL v2/v3	Caution — legal review required	If bundled in a commercial product, GPL may require the entire product to be open-sourced. Seek legal advice before including.
AGPL v3	Avoid without legal review	Network use triggers copyleft — any software that uses an AGPL component over a network must release its source code. High risk for a commercial platform.
Commercial / Proprietary	Only with explicit licence agreement	Contact connector owner. Cannot use without permission.

Action: Conduct a full licence audit of every connector before listing on the website. Maintain a licence register. Prefer MIT and Apache 2.0 connectors. Document any GPL dependencies and obtain legal sign-off before inclusion.

Implementation Risk Register

This section documents known risks across technical, business, and compliance dimensions. Each risk should be assigned an owner and mitigation plan before development begins.

Technical Risks

Risk	Severity	Likelihood	Mitigation
MCP connector instability — open-source connectors break when target apps (Zoho, Tally, Apollo) update their APIs	High	High	Fork and maintain stable tested versions. Pin to specific upstream commits. Never pull directly from GitHub main branch in production.
Tally connector complexity — Tally uses an XML-based local HTTP server, not a modern REST API. Must handle Tally ERP 9, Tally Prime, and version differences	High	High	Build a dedicated Tally XML wrapper layer. Test against all major Tally versions. Document known version-specific edge cases.
Windows installer failures — path separators, file permissions, Node.js version conflicts, antivirus interference across Windows 10/11 variants	High	Medium	Extensive Windows testing matrix. Bundle all dependencies in the installer. Add pre-flight checks for conflicting software and permissions.
Skill file encryption key management — if license server is unavailable, clients cannot decrypt and nothing works	High	Medium	Cache the decryption key locally after first validation. Implement a 7-day offline grace period. Never require online validation for every operation.
MCPX Docker dependency — MCPX runs in Docker, which may not be installed or may be blocked by corporate IT on client machines	Medium	Medium	Make MCPX optional, not mandatory. Provide a non-Docker fallback for Phase 1. Document Docker as a Phase 2/3 enterprise requirement.
Local LLM hardware requirements (Phase 3) — many Indian SMB clients have 4–8 GB RAM machines; Llama/Gemma need 16 GB+ for good performance	Medium	High	Build a hardware checker into the installer. Recommend lighter models (Phi-4, Gemma 3) for low-spec machines. Set clear minimum specs on the website.
License key security — sophisticated clients may	Medium	Low	Code obfuscation of the MCP server runtime. Server-side validation for sensitive

Risk	Severity	Likelihood	Mitigation
attempt to extract the AES decryption key from the MCP server binary			operations. Rotate encryption keys periodically with updates.
Connector abandonment — open-source maintainers stop supporting a connector; upstream repo archived or deleted	Medium	High	Maintain full forks of all listed connectors. Do not depend on upstream for production builds. Monitor upstream activity quarterly.

Business & API Risks

Risk	Severity	Likelihood	Mitigation
LinkedIn, Apollo, Lusha ToS violations — these platforms actively block automation and may prohibit MCP-style programmatic access	High	High	Use only official APIs where available. Review ToS before listing each connector. Be transparent with clients about usage limits and risks.
API rate limits causing connector failures — clients hit API rate limits mid-workflow, causing silent failures or partial data	Medium	High	Build rate limit handling and queuing into every connector. Surface rate limit errors clearly in the health dashboard. Document limits per connector.
Client credential exposure — clients paste API keys incorrectly or store them insecurely outside the skill file system	High	Medium	Provide a credential wizard in the installer. Validate credentials at setup time. Never log credentials anywhere in the system.
Competition from Zapier/n8n adding India-specific packs — large players may target the same vertical	Medium	Low	Move fast on Tally and GST-specific workflows — these are India-specific and large players are unlikely to prioritise them. Build deep vertical expertise as the moat.
Client expectation mismatch — clients expect full AI automation but local LLMs / basic connectors deliver limited capability in Phase 1	High	Medium	Set clear capability expectations during onboarding. Provide demo videos. Start with narrow, reliable use cases before broad automation.

Compliance & Legal Risks

Risk	Severity	Likelihood	Mitigation
India DPDP Act (Digital Personal Data Protection Act 2023) — implications for how client data flows through the platform, especially financial and HR data	High	High	Legal review before launch. Ensure all processing is local — no client data touches Recklabs servers. Document data flow architecture for compliance audit.
GST data handling — Tally and QuickBooks connectors may process GST-sensitive financial data; mishandling could have regulatory consequences	High	Medium	Connectors should read/write data only — no storage or aggregation on Recklabs infrastructure. Client is the data controller, Recklabs is the tool provider.
Open-source licence compliance — some GitHub connectors use GPL or AGPL licences that impose obligations on commercial products that bundle them	Medium	Medium	Licence audit of every connector before listing. Prefer MIT/Apache-2.0 licenced connectors. Document licence obligations for any GPL dependencies.

Risk Summary Matrix

Priority	Risk	Owner (Suggested)
P0 — Fix before launch	Tally connector XML complexity	Backend / Connector team
P0 — Fix before launch	Windows installer compatibility matrix	DevOps / Installer team
P0 — Fix before launch	DPDP Act legal review	Legal / Management
P0 — Fix before launch	Offline grace period for skill file decryption	Backend / Security team
P1 — Fix in first sprint	API rate limit handling in all connectors	Connector team
P1 — Fix in first sprint	LinkedIn / Apollo ToS review	Business / Legal team
P1 — Fix in first sprint	Open-source licence audit	Technical / Legal team
P2 — Monitor ongoing	Upstream connector abandonment	Connector team (quarterly review)
P2 — Monitor ongoing	Hardware requirements for Phase 3 LLM	Product team

Priority	Risk	Owner (Suggested)
P3 — Phase 3 planning	License key extraction / obfuscation	Security team

International Compliance — United States & Global Markets

Indian law alone is NOT sufficient for US clients. The US has its own complex, state-by-state patchwork of privacy and security laws that apply to any company — including Indian companies — that serves US customers. This section documents what changes, what additional requirements apply, and how the Recklabs platform and phases must be amended to accommodate international clients.

NOTE: This document is for internal planning purposes only and does not constitute legal advice. Recklabs must engage US-qualified legal counsel before onboarding any US clients.

The Fundamental Difference: India vs US Legal Landscape

Dimension	India	United States
Primary framework	Single national law — DPDP Act 2023 applies uniformly across India	No single federal privacy law. A patchwork of 20+ state laws, each with different thresholds, rights, and penalties
Applies to Recklabs?	Yes — Recklabs is incorporated in India and serves Indian clients	Yes — any company serving US residents is subject to the laws of the states those residents live in, regardless of where Recklabs is based
Consent model	Explicit, free, unconditional consent required	Varies by state — opt-out model (California, Virginia, Texas) vs opt-in for sensitive data
Key security standard	CERT-In Directions + IT Act Section 43A (reasonable security)	SOC 2 Type II — the de facto enterprise procurement requirement. Not legally mandatory but commercially essential
Breach notification	72 hours to DPBI	Varies: 72 hours (federal proposals), 30-90 days in most states; some states require notification within 30 days
Financial data rules	IT Act + DPDP Act	SOX (Sarbanes-Oxley) for public companies; sector-specific RBI-equivalent is the SEC/FINRA/FTC
AI-specific rules	Not yet enacted (expected in future legislation)	California ADMT rules effective Jan 2026; Colorado AI Act; EU AI Act applies to EU clients

US Laws That Apply to Recklabs When Serving US Clients

1. California — CCPA/CPRA (Most Important US State Law)

California has the most comprehensive and strictly enforced state privacy law in the US. If Recklabs serves even one California-based business client, CCPA obligations apply.

CCPA Threshold	Does Recklabs Likely Qualify?
Annual gross revenue exceeds $26.6M	Not initially — but monitor as revenue grows
Processes personal data of 100,000+ California residents/households annually	Possible — a single US enterprise client could bring this volume through CRM/HR connectors
Derives 50%+ revenue from selling/sharing personal data	No — Recklabs does not sell data

Even if Recklabs does not meet CCPA thresholds initially, clients who ARE subject to CCPA will contractually require Recklabs to comply as their data processor/service provider. This is effectively a commercial mandate even before it becomes a legal one.

Key CCPA/CPRA Requirements for Recklabs

- Privacy notice in plain English specifying exactly what data categories are collected, why, and who receives them
- Right to know — respond to consumer access requests within 45 days
- Right to deletion — delete consumer data within 45 days of verified request
- Right to opt out of sale/sharing — Recklabs must not sell or share client data for advertising purposes (already satisfied by local-first architecture)
- Data Processing Agreements (DPAs) with all US clients — CCPA requires service providers to have written contracts specifying the permissible purposes of data processing
- Global Privacy Control (GPC) signal recognition — required by California, Colorado, and Connecticut as of 2025. Recklabs' website must honour GPC opt-out signals
- New from January 2026 — Automated Decision-Making Technology (ADMT) risk assessments required for AI processing activities presenting 'significant risk' to consumers

2. Other Active US State Laws (As of April 2026)

Twenty US states now have comprehensive privacy laws. The most relevant for Recklabs' target verticals are:

State	Law	Threshold	Key Difference from CCPA
Virginia	VCDPA	100K residents OR 25K + 50% revenue from data sales	Opt-out model. No private right of action. AG enforcement only.

State	Law	Threshold	Key Difference from CCPA
Texas	TDPSA	Business in Texas processing TX resident data (small biz exempt)	Applies if doing business in Texas. Similar to Virginia model.
Colorado	CPA	100K residents OR 25K + 50% revenue from data sales	Requires GPC signal recognition. Data protection assessments required.
New York	Expected 2026/2027	Legislation advancing	Watch closely — NY is major financial hub. Stricter than CCPA proposed.
Maryland	MODPA	35K residents OR 10K + 20% revenue from data sales	Strictest data minimisation requirement of any US state — collect only what's necessary
Indiana, Kentucky, Rhode Island	Effective Jan 2026	100K residents (Indiana/Kentucky); 35K (Rhode Island)	Virginia-style frameworks with 30-day cure provisions

3. Federal Laws — Sector-Specific (Apply Regardless of State)

Federal Law	When It Applies to Recklabs	Key Requirement
COPPA (Children's Online Privacy Protection Act) — updated June 2025	If any connector could process data of users under 13 (HR systems, education platforms)	Verifiable parental consent before collecting any data from under-13 users. Compliance deadline April 22, 2026.
HIPAA (Health Insurance Portability and Accountability Act)	If Recklabs builds health sector connectors (Phase 2/3) or handles Protected Health Information (PHI)	BAA (Business Associate Agreement) required with every healthcare client. Strict encryption, access, and audit requirements.
SOX (Sarbanes-Oxley Act)	If US public company clients use QuickBooks/accounting connectors	Recklabs is not directly subject but clients may require SOX-compliant audit trails from their vendors. MCPX audit logs directly address this.
FTC Act Section 5 — Unfair or Deceptive Practices	Applies to all US commercial activity	Privacy policy must accurately reflect actual data practices. Deceptive privacy notices attract FTC enforcement regardless of state law.

SOC 2 — The Commercial Reality for US Enterprise Sales

SOC 2 is not a law — but it is commercially mandatory for selling to US enterprise clients. This is the single most important compliance action Recklabs must take to succeed in the US market.

SOC 2 Fact	Data Point
Enterprise buyers requiring SOC 2 before signing contracts	83% (Vanta 2025 survey)
Enterprise buyers at 5,000+ employees requiring SOC 2	91%
Startups reporting SOC 2 directly enabled deal closures	67%
Deals lost specifically due to absence of SOC 2	Over 35% of enterprise deals
Typical SOC 2 Type I cost	$10,000 — $25,000 USD
Typical SOC 2 Type II cost	$25,000 — $50,000 USD + internal preparation time
Time to achieve Type I	2 — 4 months from readiness assessment
Time to achieve Type II	Additional 6 — 12 month observation period after Type I

SOC 2 Type I vs Type II — Which Does Recklabs Need?

- SOC 2 Type I — confirms security controls are properly designed at a point in time. Faster (2-4 months). Good for early US market entry and initial sales conversations.
- SOC 2 Type II — confirms controls functioned consistently over 6-12 months. Required by serious US enterprise clients before signing contracts involving sensitive data.
- Recommended path: Pursue Type I before first US client onboarding; achieve Type II within 12-18 months of US market entry.

What SOC 2 Requires Recklabs to Implement

SOC 2 Trust Service Criteria	Controls Required	Already Planned?
Security (mandatory)	Firewalls, MFA, endpoint protection, RBAC, penetration testing, vulnerability management	Partially — MFA and RBAC need to be explicitly designed
Availability	Backup strategy, failover for license server, uptime monitoring, disaster recovery plan	Not yet planned — needs to be added to architecture
Confidentiality	Encryption at rest and in transit (TLS), data classification, access controls for confidential data	Partially — AES-256 for skill files planned; TLS for server communications planned
Processing Integrity	Change management, version control, automated validation, error handling in connectors	Partially — connector versioning planned; formal change management not yet documented

SOC 2 Trust Service Criteria	Controls Required	Already Planned?
Privacy	Privacy notice, consent, data subject rights workflows, retention and deletion	Partially — DPDP compliance covers much of this; US-specific workflows needed

Architecture Changes Required for US Clients

What Is Already Compliant (No Change Needed)

- Local-first architecture — client data never touches Recklabs servers. This is a major compliance advantage in both India and the US.
- AES-256 encryption of skill files — satisfies both Indian IT Act Section 43A and US SOC 2 confidentiality criteria.
- No data aggregation or sale — Recklabs does not sell client data; opt-out rights are inherently satisfied.

What Must Be Added or Changed for US Clients

Required Change	Why	Phase to Implement
Jurisdiction-aware privacy notice — separate or configurable notice for US users	CCPA requires specific California-mandated disclosures different from DPDP notice. Texas, Virginia etc. have different requirements.	Phase 1 — before first US client
US-specific Data Processing Agreements (DPAs)	CCPA requires written service provider contracts specifying permissible processing purposes. Different from Indian DPDP contracts.	Phase 1 — before first US client
Global Privacy Control (GPC) signal recognition on website	Mandatory in California, Colorado, Connecticut as of 2025. Website must honour opt-out browser signals.	Phase 1 — website build
45-day deletion and access response workflow (CCPA)	India requires 7-day erasure; US requires 45-day. System must track and respond to both.	Phase 1 — subscription system
SOC 2 Type I certification	Without it, US enterprise deals will not progress past security review.	Phase 2 — begin process at Phase 1 launch
Breach notification adapted for US — state-specific timelines	30 states have breach notification laws. Some require 30-day notification	Phase 1 — incident response plan

Required Change	Why	Phase to Implement
	vs India's 72-hour to regulator.	
ADMT risk assessment for AI workflows (California, effective Jan 2026)	Any AI processing presenting 'significant risk' to consumers requires documented risk assessment.	Phase 2 — when multimodal AI workflows are deployed
SOC 2 Type II certification	Required for serious US enterprise contracts. Needed before Phase 3 enterprise push.	Phase 3 — target achievement before US enterprise sales
HIPAA Business Associate Agreements (if health sector)	Any connector touching healthcare data requires a signed BAA and HIPAA-compliant security controls.	Phase 3 — only if health sector connectors are built

Global Compliance Summary — All Target Markets

Market	Primary Laws	Key Requirement Beyond India	When to Activate
India	DPDP Act 2023, IT Act 43A, CERT-In 2022	Already documented in Indian compliance section	Before launch
United States	CCPA/CPRA, 20+ state laws, FTC Act, COPPA, HIPAA (if health)	SOC 2 Type II; US DPAs; GPC signal; ADMT risk assessments	Phase 1 (basic); Phase 2-3 (full)
European Union / UK	GDPR (EU); UK GDPR	DPA/DPO appointment; Standard Contractual Clauses for data transfers; legitimate interest basis; 72hr breach notification to DPA	Phase 3 — when EU clients are actively pursued
UAE / Middle East	UAE PDPL (Personal Data Protection Law, effective Sept 2022)	Explicit consent; data localisation requirements in some sectors; Data Protection Officer if processing at scale	Phase 4 — evaluate on client-by-client basis
Singapore / Southeast Asia	PDPA (Personal Data Protection Act)	Purpose limitation; data breach notification within 3 days; DPO recommended	Phase 4 — evaluate on client-by-client basis
Australia	Privacy Act 1988 + Australian Privacy Principles	13 Australian Privacy Principles; breach notification to OAIC within 30 days; data residency in Australia for government clients	Phase 4 — evaluate on client-by-client basis

Phase-by-Phase Compliance Amendments for International Expansion

Phase 1 Amendments for US Clients

- Add a US client flag to the subscription system — triggers US-specific privacy notice, DPA, and GPC compliance automatically
- Build jurisdiction detection into the website — serve CCPA-compliant notice to US visitors, DPDP-compliant notice to Indian visitors
- Prepare both Indian DPA template and US Service Provider Agreement template before first client of each type
- Begin SOC 2 Type I readiness assessment in parallel with Phase 1 build — do not wait until Phase 2
- Add 45-day CCPA deletion/access workflow alongside the 7-day DPDP erasure workflow
- Implement GPC signal recognition on the Recklabs website

Phase 2 Amendments for US Clients

- ADMT (Automated Decision-Making Technology) risk assessment required for all AI-powered multimodal workflows serving California clients — document before deployment
- SOC 2 Type I should be achieved before Phase 2 goes live for US clients
- Multimodal connectors processing biometric data (voice, face in images) face stricter US state laws — Illinois BIPA (Biometric Information Privacy Act) requires explicit written consent and prohibits selling biometric data
- Industry pack DPAs for US verticals must reference sector-specific laws — e.g., US Sales Pack DPA references CCPA; US HR Pack DPA references state employment privacy laws

Phase 3 Amendments for US Enterprise

- SOC 2 Type II certification is a prerequisite for US enterprise contracts — must be achieved before Phase 3 US enterprise sales begin
- Air-gapped deployments for US government or regulated finance clients may require FedRAMP assessment (Federal Risk and Authorization Management Program) — separate programme, significant investment, evaluate on a case-by-case basis
- Fine-tuning service using client data requires explicit written consent under both CCPA and applicable state laws — add this to the fine-tuning service contract template
- HIPAA Business Associate Agreements required if any health sector connectors are built — treat as a separate compliance programme with dedicated legal counsel

Compliance Cost Estimates — US Market Entry

Compliance Activity	Estimated Cost (USD)	When Needed
US-qualified privacy legal counsel (DPAs, privacy notices, CCPA compliance review)	$5,000 — $15,000	Before first US client
SOC 2 Type I audit	$10,000 — $25,000	Phase 1-2 boundary
SOC 2 Type II audit	$25,000 — $50,000	Phase 2-3 boundary
Compliance automation platform (Vanta, Drata, or Sprinto) — reduces audit prep by 60-70%	$10,000 — $20,000/year	Phase 2 onwards
Penetration testing (required for SOC 2)	$5,000 — $15,000 per engagement	Annual from Phase 2
HIPAA legal counsel and BAA templates (if health sector)	$10,000 — $30,000	Phase 3 only if applicable
Total Phase 1 US compliance cost estimate	$15,000 — $40,000	Before first US client
Total Phase 2-3 US compliance cost estimate	$60,000 — $120,000	Cumulative over 2-3 years

These costs are investments, not expenses. SOC 2 certification alone enables enterprise deal closures at median deal sizes of $120,000+ USD. The compliance cost pays back on the first 1-2 US enterprise contracts.

Strategic Technology: MCPX by Lunar.dev

This section documents a key third-party infrastructure component — MCPX by Lunar.dev — that Recklabs should evaluate for integration into its platform architecture, particularly from Phase 1 Enterprise onwards.

What is MCPX?

MCPX is an open-source MCP Gateway — a security and governance layer that sits between AI agents (Claude Desktop, n8n, Cursor etc.) and all MCP servers (connectors). Every tool call passes through MCPX, which controls access, logs activity, and manages credentials securely.

Think of it as the traffic cop and security gate for your entire MCP connector stack:

Layer	Component
AI Brain	Claude Desktop / Local LLM (Ollama)

Layer	Component
↓ Gateway Layer	MCPX — access control, audit, credentials
↓ Connector Layer	Zoho, Tally, Apollo, Lusha, QuickBooks, LinkedIn...

What Does MCPX Do?

Open Source (Free — MIT License)

- Single governed entry point for all MCP server connections
- Tool Groups — show different connectors to different users or agents on the same installation
- Tool Customisation — rewrite tool descriptions, lock parameters without modifying the underlying connector
- Remote MCP Authentication — OAuth support for all connectors out of the box
- Real-time Metrics — Prometheus-compatible monitoring with labels for tool name, error state, agent, and model
- Basic Audit Logs — who called which connector tool and when
- Works with Claude Desktop, Claude Code, VS Code, n8n, Cursor, and any MCP-compatible client

Enterprise Tier (Paid — Custom Quote)

- Full RBAC — role-based access control per user, team, or workflow at global, service, and tool level
- Immutable Audit Trails — full chain: User → Agent → MCP Server → Tool called — non-repudiable logs
- Credential / Secrets Isolation — API keys managed by reference only, never exposed in config files or to end users
- Automated Risk Scoring — every MCP server analyzed for vulnerabilities before users can connect
- Private MCP Registry — publish and govern internal MCP servers across the organisation
- IDP / SSO Integration — connect Okta, Azure AD, or any identity provider
- Self-hosted in Kubernetes — full on-premise deployment under a dedicated namespace
- SLA and enterprise support

MCPX Revenue Model

Tier	Price	Target Customer
Free / OSS	₹0 — MIT open-source	Developers, small teams, self-hosted experimenters

Tier	Price	Target Customer
Team	$250 / gateway / month	Growing teams needing production reliability, up to 10 managed APIs, 2M flow runs/month
Enterprise	Custom quote	Large enterprises, regulated industries — Fortune 200 companies already on this tier

Lunar.dev uses a classic open-core model — the core gateway is free and open-source, and they charge for enterprise governance, compliance, hosted deployment, and SLAs. They are SOC 2 certified at the Enterprise tier and recognised by Gartner as a Representative Vendor in the MCP Gateways category.

How and When Should Recklabs Use MCPX?

Phase	MCPX Role	Version to Use	Cost to Recklabs
Phase 1 — SMB clients	Optional — not required for basic single-user setups. Local MCP server handles connections directly.	Not needed	₹0
Phase 1 — Enterprise pilot clients	Bundle MCPX OSS in the installer as the gateway layer. Gives enterprise clients access control and basic audit logs from Day 1.	Free OSS (MIT)	₹0
Phase 2 — Multi-user team clients	MCPX Tool Groups become valuable — Accounts team sees Tally/QuickBooks, Sales team sees Apollo/Lusha — same installation, different tool views.	Free OSS (MIT)	₹0
Phase 3 — Air-gapped enterprise	MCPX Enterprise adds the compliance and governance layer that banks, legal firms, and government clients require — immutable audit trails, secrets isolation, Kubernetes self-hosting.	Enterprise (paid)	Bundle into client pricing

Partner or Compete? — Strategic Position

Recklabs should position MCPX as a complementary infrastructure partner, not a competitor. The two products solve completely different problems for completely different buyers:

MCPX Does	Recklabs Does
Security, governance, and access control	Connector curation, packaging, and skill files

MCPX Does	Recklabs Does
Infrastructure and gateway layer	Business application and workflow layer
Targets enterprise IT and security teams	Targets business owners, CA firms, and sales managers
Sells to developers and CTOs	Sells to non-technical business users
Solves: How do we govern this securely?	Solves: How do we make this useful for our Tally-using CA firm?

Recommended approach: In the Recklabs installer, optionally bundle MCPX OSS as the gateway layer at no extra cost. For enterprise clients who require full governance and compliance, recommend MCPX Enterprise as a certified add-on. This strengthens the Recklabs enterprise pitch without requiring Recklabs to build security infrastructure from scratch.

Think of it this way: MCPX is the plumbing. Recklabs is the finished kitchen. Clients need both, but they buy them for completely different reasons.

Competitive Context: Other MCP Gateways

MCPX is the leading open-source MCP gateway but is not the only option. The team should be aware of alternatives when evaluating the gateway strategy:

Gateway	Strengths	Limitations
MCPX (Lunar.dev)	Purpose-built for MCP governance, SOC 2, Tool Groups, Gartner recognised	Enterprise features are paid; IDP integration requires Enterprise tier
Docker MCP Gateway	Container-per-server isolation, cryptographically signed images	No built-in access control or audit trails — security via isolation not policy
Microsoft MCP Gateway	Deep Azure / Entra ID integration, enterprise familiar	Locked into Microsoft ecosystem, heavy infrastructure requirement
IBM ContextForge	Strong enterprise pedigree, policy engine	Complex setup, overkill for SMB use cases

For Phase 1 and 2, MCPX OSS is the clear recommendation — it is the most capable free option and aligns with the Recklabs open-source philosophy. Revisit other options only if a specific enterprise client has existing Microsoft or IBM infrastructure requirements.

End of Document

For questions or contributions, please circulate feedback before the next planning session.